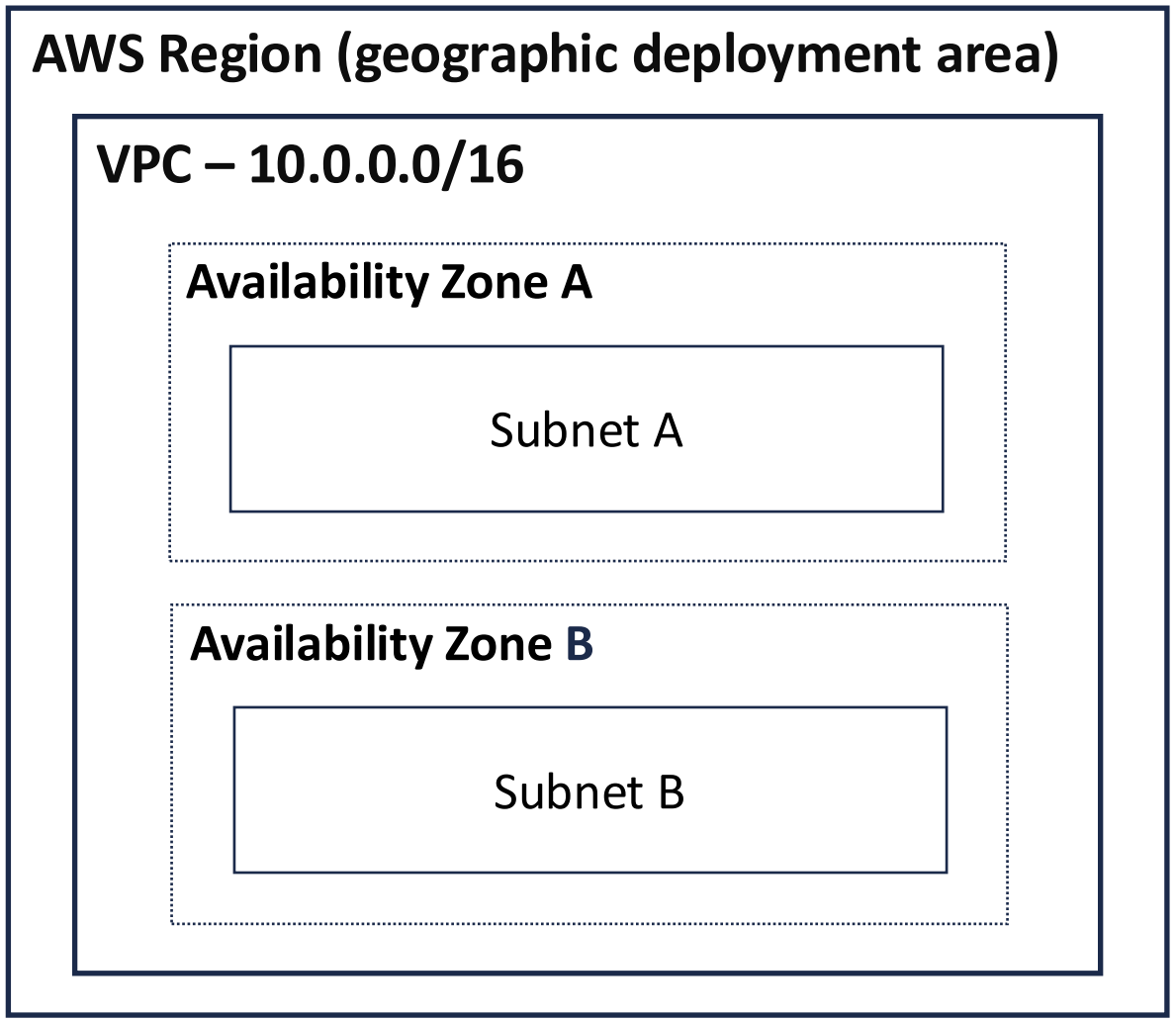
# AWS VPC Networking and Security

## Cloud Security

CSE4059

# Virtual Private Cloud




- A Virtual Private Cloud (VPC) is a logically isolated network for AWS resources
  - A VPC provides an address range for its resources
- A VPC belongs to one Region and can contain subnets in several Availability Zones (AZs)
  - An Availability Zone is an isolated location within a Region
  - Deploying resources across multiple AZs helps maintain service availability if one AZ fails

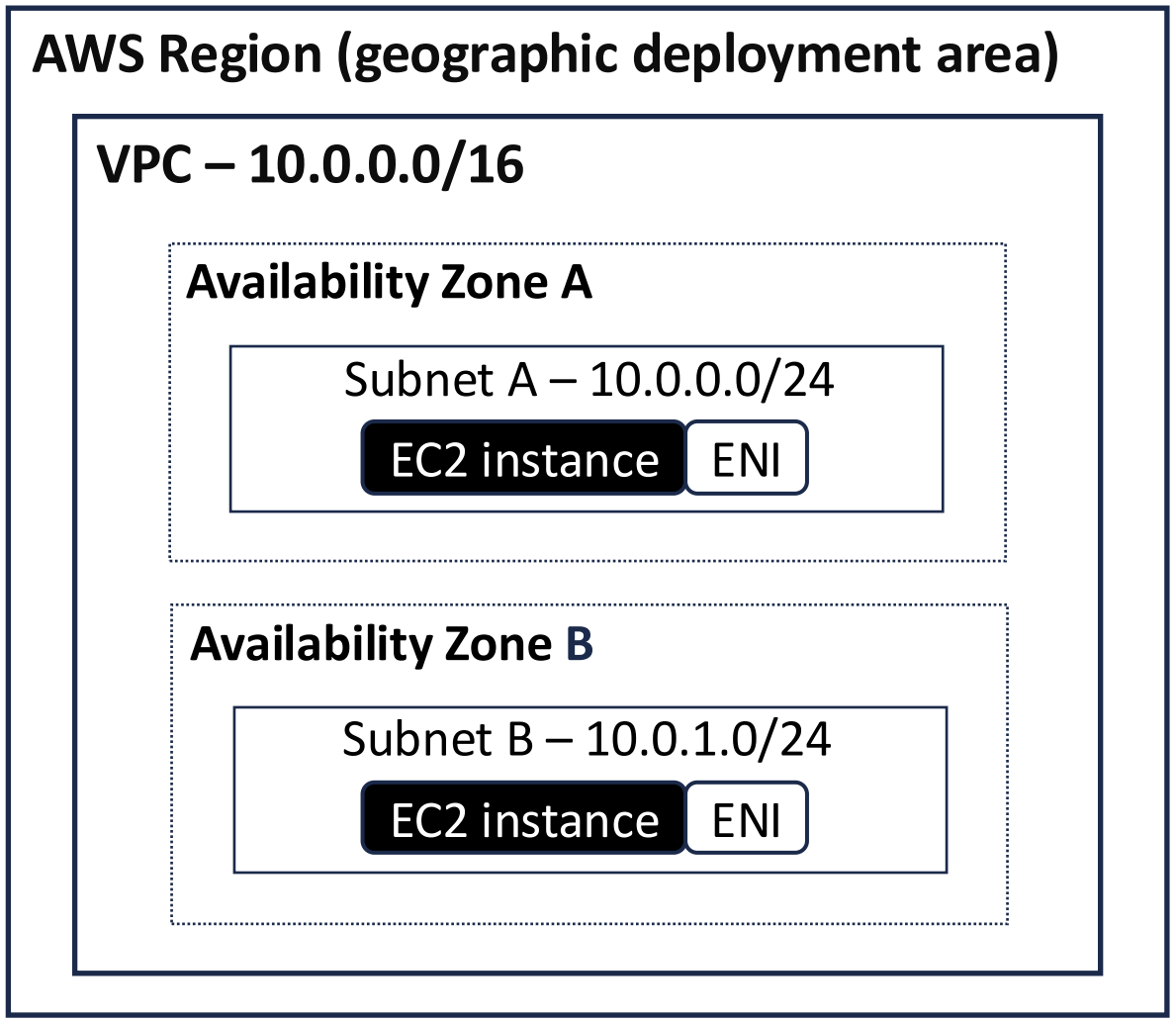
# CIDR: IPv4 Address Ranges

- Classless Inter-Domain Routing (CIDR) uses address/prefix length to describe an IP address range
  - An IPv4 address consists of 32 bits, displayed as four decimal numbers (8 bits each)
  - /n fixes the first n bits; the remaining bits vary

- A larger prefix length describes a smaller address range

| CIDR block | Fixed part | Address range (inclusive) |
|---|---|---|
| 10.0.0.0/16 | 10.0 (16 bits) | 10.0.0.0 – 10.0.255.255 |
| 10.0.0.0/24 | 10.0.0 (24 bits) | 10.0.0.0 – 10.0.0.255 |
| 203.0.113.10/32 | All 32 bits | 203.0.113.10 only |
| 0.0.0.0/0 | No fixed bits | All IPv4 addresses |

# Subnets and Network Interfaces




- A subnet is part of a VPC address range, located in one Availability Zone
  - Different subnets can use different routes and traffic controls
- An Elastic Network Interface (ENI) is a virtual network interface that connects an EC2 instance to a subnet
  - Its private IPv4 address is assigned from the subnet's address range
  - Ex) ENI in Subnet A: 10.0.0.10 / ENI in Subnet B: 10.0.1.10

# Route Tables

| Destination | Target |
|---|---|
| 10.0.0.0/16 | Local – within the VPC |
| 0.0.0.0/0 | Internet Gateway (IGW) |

- A route table determines where packets are sent based on their destination IP addresses
  - Each subnet is associated with one route table
  - Among matching routes, the one with the longest prefix is selected
- An internet gateway (IGW) connects a VPC to the internet
- Routes determine where traffic goes; traffic filters determine whether it is allowed

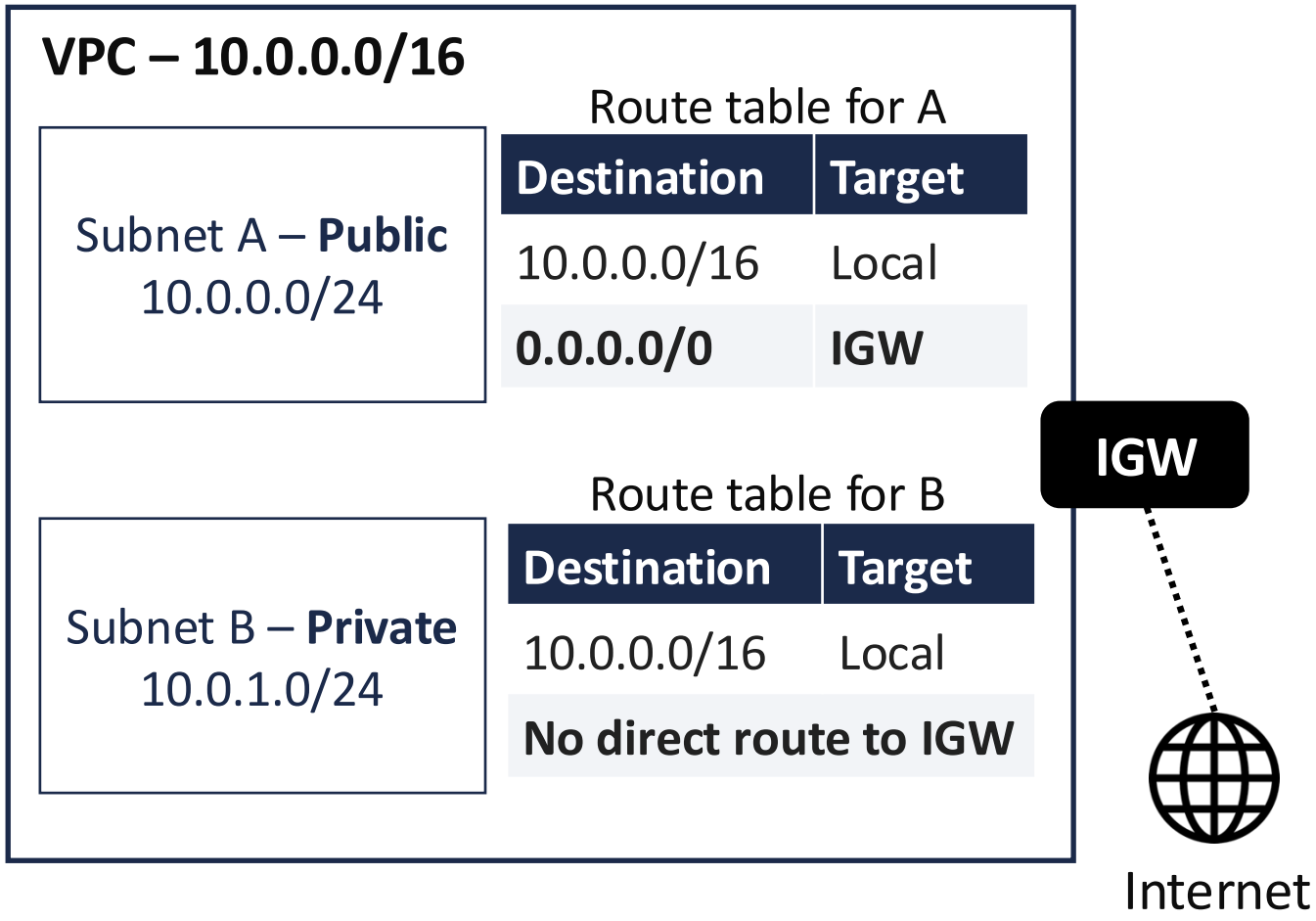
# Following a Destination

| Destination | Target |
|---|---|
| 10.0.0.0/16 | Local – within the VPC |
| 0.0.0.0/0 | Internet Gateway (IGW) |

| Destination | Matching routes | Selected target |
|---|---|---|
| 10.0.1.10 | 10.0.0.0/16 and 0.0.0.0/0 | local |
| 203.0.113.10 (example) | 0.0.0.0/0 | Internet gateway (IGW) |

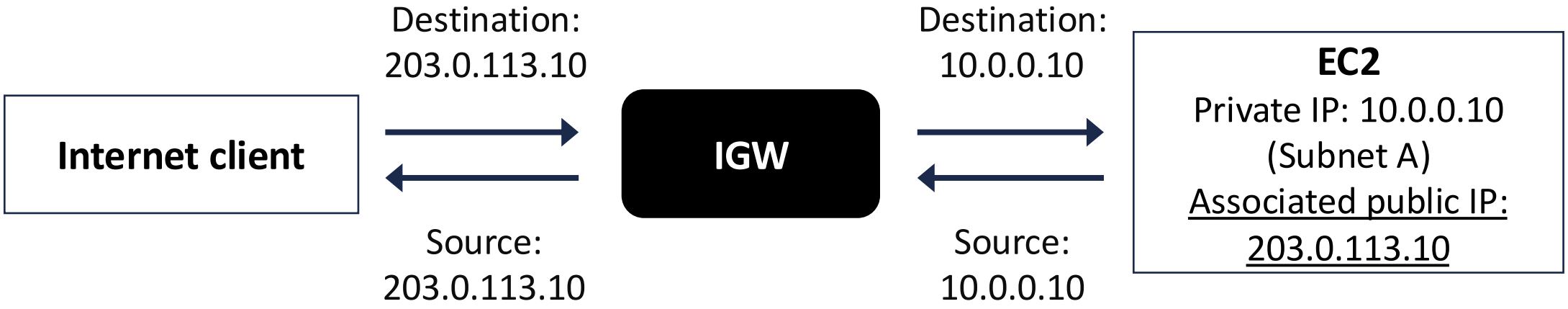
- 10.0.1.10 matches both routes, but /16 is selected because it is more specific than /0
- 0.0.0.0/0 is the default route
  - It matches all IPv4 addresses and is used when no more specific route matches

# Public and Private Subnets



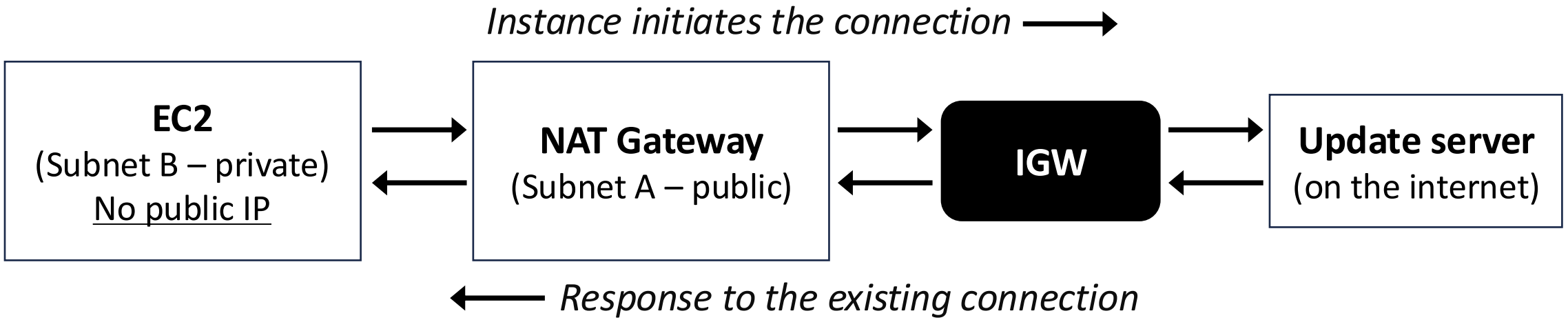

- A subnet's route table determines whether it is public or private
  - A public subnet has a direct route to an internet gateway attached to the VPC
  - A private subnet has no direct route to an internet gateway
- A public subnet alone does not guarantee internet access
  - An EC2 instance also needs an associated public IPv4 address and traffic rules that allow the connection for direct IPv4 internet access

# Internet Gateway Address Mapping



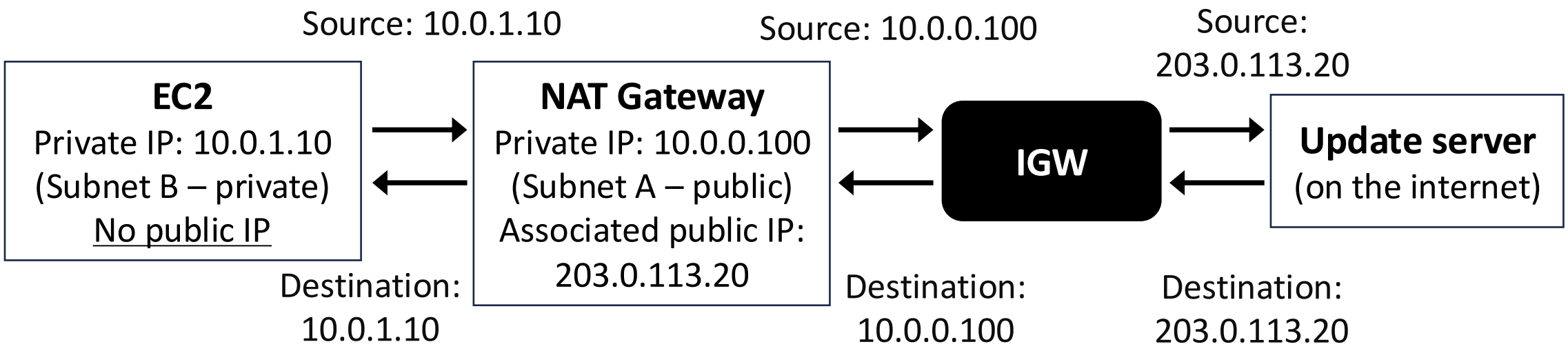

- An EC2 instance uses a private IPv4 address on its network interface
  - Internet clients connect using the instance's associated public IPv4 address
- For IPv4, the IGW performs one-to-one Network Address Translation (NAT)
  - Incoming packets: the destination changes from the public IP to the private IP
  - Outgoing packets: the source changes from the private IP to the public IP

# NAT Gateway for Private Subnets



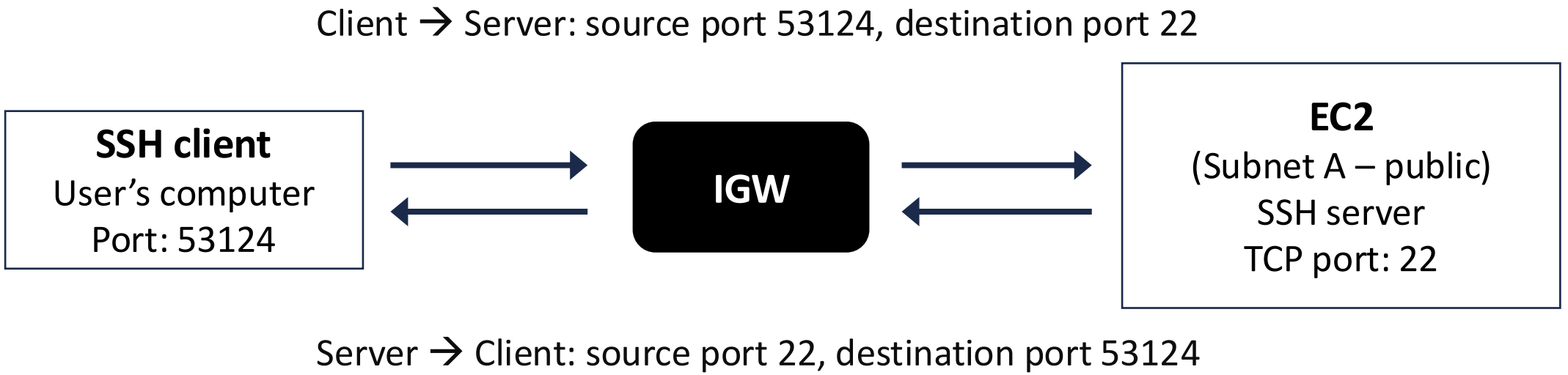

- EC2 instances in private subnets may need internet access to download updates or call external APIs.
- A public NAT gateway allows these instances to initiate IPv4 internet connections without their own public IP addresses
  - Traffic reaches the internet through the NAT gateway and the IGW
- The instances can receive responses to connections they initiate
  - Internet hosts cannot initiate new connections to these instances through the NAT gateway

# NAT Gateway: Address Translation




- The outgoing packet's source IPv4 address changes at two points
  - The NAT gateway replaces the EC2 instance's private IP with its own private IP
  - The IGW translates the NAT gateway's private IP to its associated public IP
- The external server sees the NAT gateway's associated public IP as the source
- For the response, the IGW and NAT gateway reverse the address translations to deliver the packet to the original EC2 instance

# SSH Connection Example




- SSH provides secure remote login, typically using TCP port 22
  - In this example, an SSH client on the user's computer connects to the EC2 instance's public IPv4 address
- The client uses an ephemeral source port (ex. 53124)
  - Client-to-server packets have destination port 22
  - Server-to-client packets have destination port 53124, the client's selected port

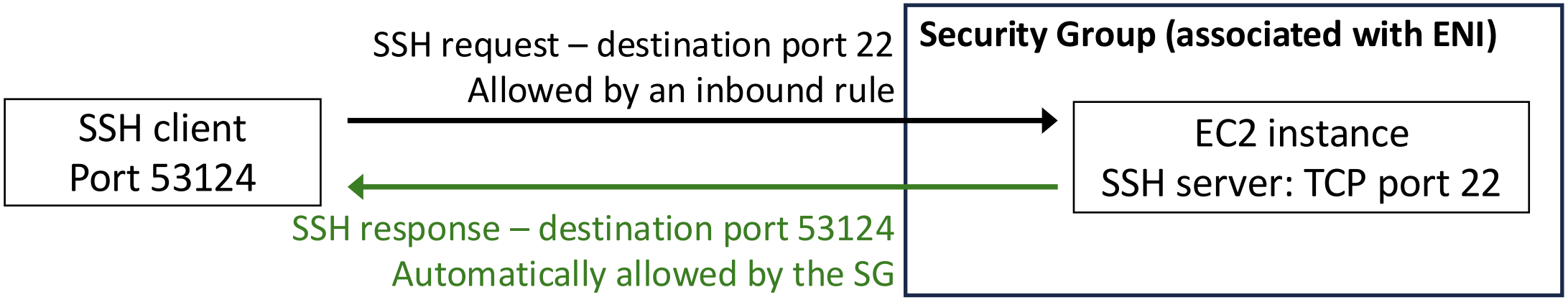
# Direct IPv4 SSH Access

*Assume the EC2 instance is running, the SSH server is listening on TCP port 22, and traffic filters allow the connection

| Case | Public IPv4 address on EC2 | Subnet route to IGW | Expected TCP connection |
|---|---|---|---|
| 1 | Assigned | Configured | Succeed |
| 2 | Not assigned | Configured | Fail |
| 3 | Assigned | Not configured | Fail |

- Direct IPv4 access from the internet requires both an associated public IPv4 address and a subnet route to the IGW
- With addressing and routing in place, traffic filters determine whether the connection is allowed

# Security Groups: Stateful Filtering




- A security group (SG) acts as a virtual firewall for an EC2 instance's network interface (ENI)
  - Inbound rules control incoming traffic, and outbound rules control outgoing traffic
- Security groups contain allow rules only
  - New connections without a matching allow rule are blocked
- Security groups are stateful: they track allowed connections
  - Response traffic is automatically allowed without a separate SG rule in the opposite direction

# Reading a Security Group Rule

Assume one attached security group with a single inbound rule

| Protocol | Destination port | Source |
|---|---|---|
| TCP | 22 | 198.51.100.10/32 |

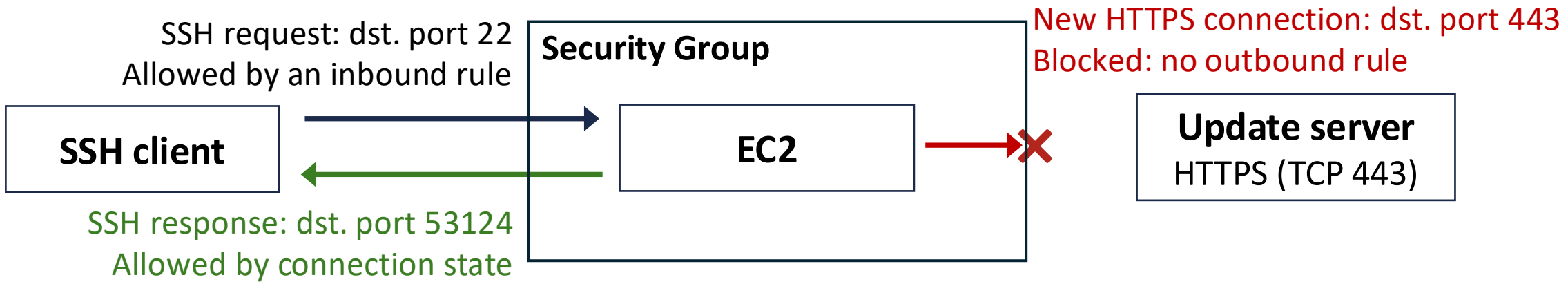
**New inbound traffic**

| Source | Protocol | Destination port | SG decision |
|---|---|---|---|
| 198.51.100.10 | TCP | 22 | Allow |
| 198.51.100.10 | TCP | 443 | Block |
| 198.51.100.20 | TCP | 22 | Block |
| 198.51.100.10 | UDP | 22 | Block |

- New inbound traffic must match the source, protocol, and destination port in the same allow rule
  - Traffic that matches no inbound rule is blocked
- The source 198.51.100.10/32 limits this rule to one IPv4 address

# Tracked Replies and New Connections

- Example SG configuration
  - Inbound: Allow TCP port 22 from 198.51.100.10/32
  - Outbound: No rules
  - Assume routing and other traffic filters permit communication




- The SSH response belongs to the allowed connection
  - The SG allows the response without a separate outbound rule
- A new HTTPS connection initiated by EC2 requires an outbound allow rule
  - With no outbound rules, the SG blocks this new connection

# Combined Security Group Rules

- Multiple security groups can be attached to the same network interface
  - Their allow rules are combined

**Example**: each group has one inbound rule

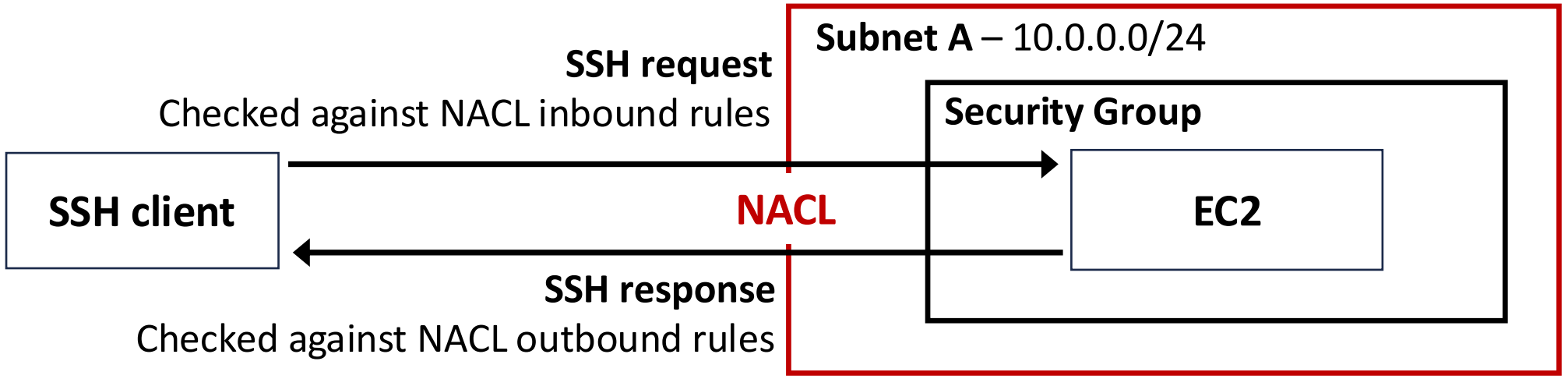
| Security group | Protocol | Destination port | Source |
|---|---|---|---|
| A | TCP | 22 | 198.51.100.10/32 |
| B | TCP | 22 | 0.0.0.0/0 |

**New connection**: client 198.51.100.20 to TCP port 22

| Attached security groups | SG decision | Reason |
|---|---|---|
| A only | Block | No matching allow rule |
| A + B | Allow | Matches the rule in B |
| B only | Allow | Matches the rule in B |

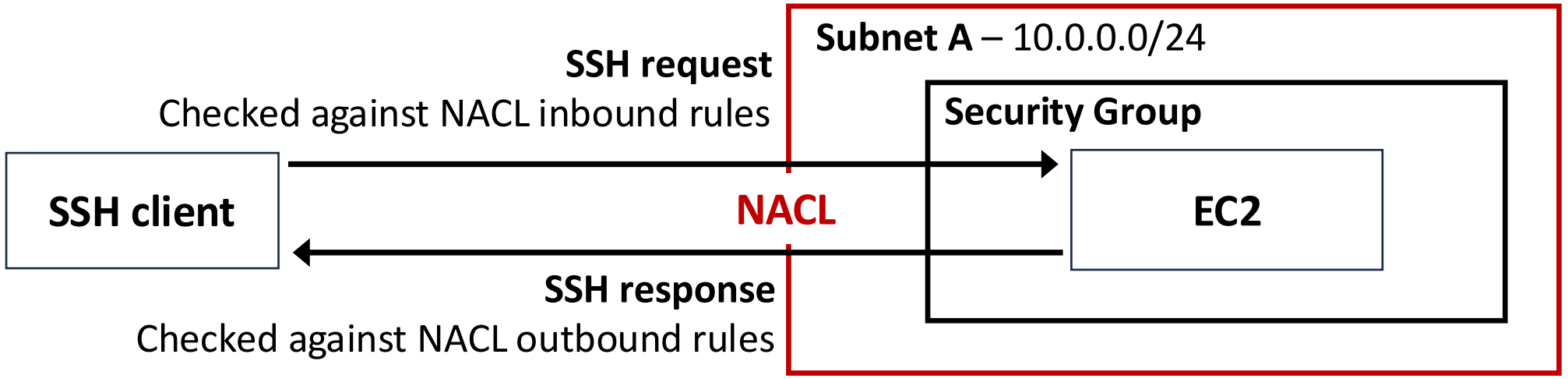
- A new connection is allowed if any attached SG has a matching allow rule
- Adding a more restrictive SG does not override another SG's allowance

# Network ACLs: Subnet Boundaries



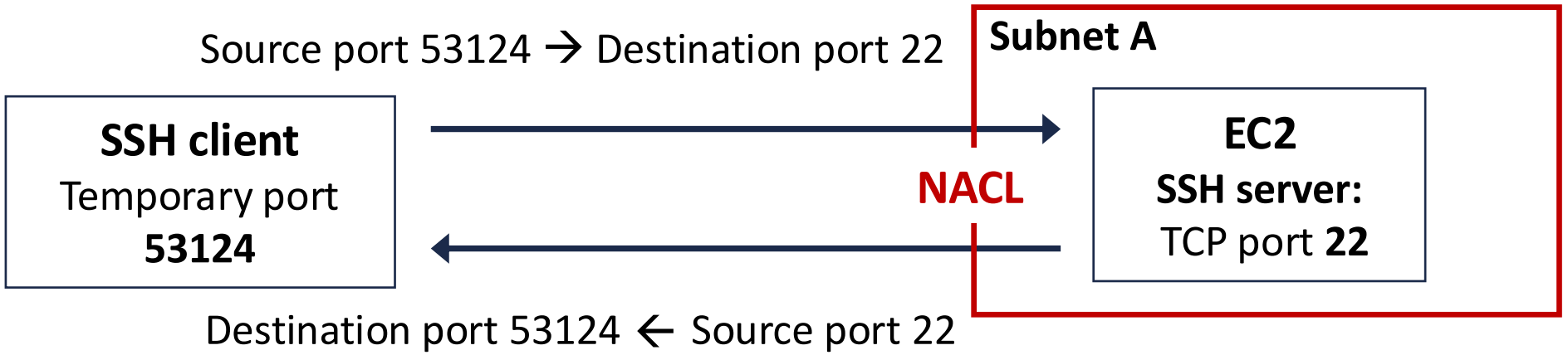

- A Network Access Control List (NACL) filters traffic entering or leaving a subnet
- NACL rules can explicitly allow or deny traffic
  - Rules are evaluated from the lowest rule number
  - The first matching rule determines the result
- NACLs are stateless: they evaluate request and response traffic independently
  - Allowing an inbound request does not automatically allow the outbound response

# Replacing a Subnet's NACL




- Each subnet is associated with exactly one NACL at a time
  - Associating a different NACL replaces the existing association
  - The old and new rule sets are not combined
- Before associating the custom NACL, add the required allow rules
  - Allow both inbound SSH requests and outbound responses

# Return Traffic Has a Different Destination Port




- An SSH connection uses server port 22 and a temporary client port
  - In this example, the client uses port 53124
  - This temporary (ephemeral) port can vary between connections
- NACL rules must permit the destination port in each direction
  - Inbound request: destination port 22
  - Outbound response: destination port 53124

# Evaluating the Response Packet

- **SSH response**: TCP source port 22 → destination port 53124
- **Destination IP**: 198.51.100.10
- Each row represents a separate configuration
  - One outbound TCP allow rule, followed by the final * (default) deny rule

| Destination port | Destination | NACL decision | Reason |
|---|---|---|---|
| 22 | 198.51.100.10/32 | Deny | Destination port does not match |
| 53124 | 198.51.100.10/32 | Allow | Exact port match |
| 1024-65535 | 198.51.100.10/32 | Allow | Range includes port 53124 |

- An outbound rule for destination port 22 does not match this response
- Allowing destination port 53124 permits this response, but the client's temporary port can change
  - A port range can cover different temporary client ports

# Rule Order Changes the Result

- NACL rules are evaluated in ascending rule-number order
- Evaluation stops at the first matching rule

**Incoming packet**: TCP from 198.51.100.10 to destination port 22

| Rule | Protocol | Destination port | Source | Action |
|---|---|---|---|---|
| 90 | TCP | 22 | 198.51.100.10/32 | Deny |
| 100 | TCP | 22 | 198.51.100.10/32 | Allow |
| * | ALL | All | 0.0.0.0/0 | Deny |

- **Rule 90 matches first**: the packet is denied
  - Rule 100 is not evaluated

# Rule Order Changes the Result

- NACL rules are evaluated in ascending rule-number order
- Evaluation stops at the first matching rule

**Incoming packet**: TCP from 198.51.100.10 to destination port 22

| Rule | Protocol | Destination port | Source | Action |
|---|---|---|---|---|
| ~~90~~ **110** | TCP | 22 | 198.51.100.10/32 | Deny |
| 100 | TCP | 22 | 198.51.100.10/32 | Allow |
| * | ALL | All | 0.0.0.0/0 | Deny |

- Rule 90 matches first: the packet is denied
  - Rule 100 is not evaluated
- **If the deny rule is moved from 90 to 110, rule 100 matches first**
  - The packet is allowed, and rule 110 is not evaluated

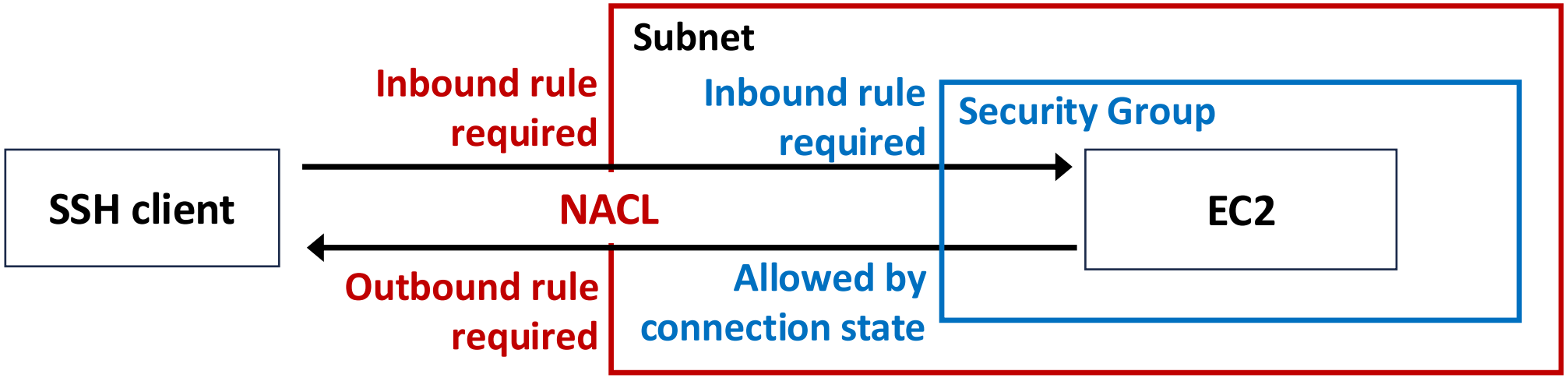
# Security Group vs. Network ACL

| Property | Security Group (SG) | Network ACL (NACL) |
|---|---|---|
| Applied at | Network interface (ENI) | Subnet boundary |
| Association | Multiple SGs per ENI | One NACL per subnet at a time |
| Rule actions | Allow only | Allow and deny |
| Rule evaluation | Allow rules across attached SGs are combined | First matching rule in ascending number order |
| Connection tracking | Stateful | Stateless |
| Response traffic | Automatically allowed for an allowed connection | Checked independently against return-direction rule |

- Traffic must pass all applicable SG and NACL checks
- SG connection state does not bypass NACL rules

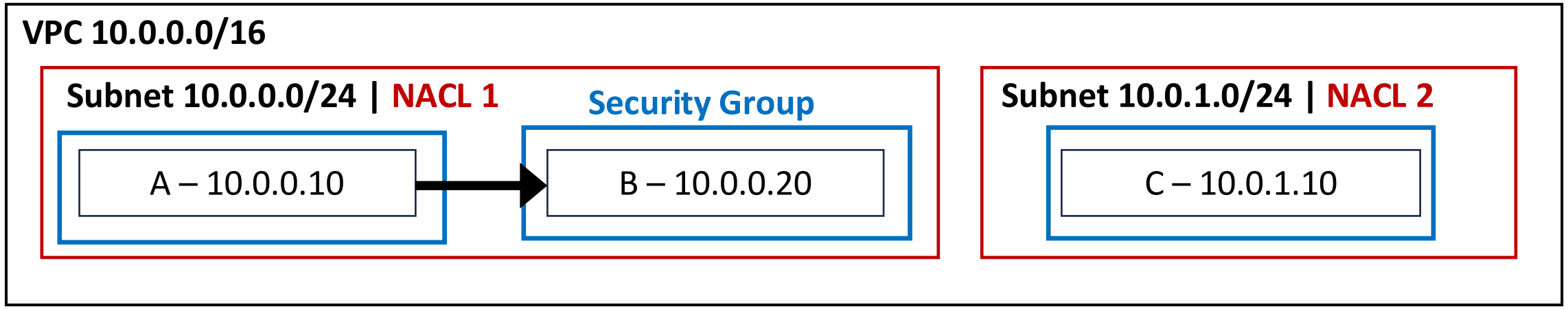
# SSH Through Both Filters

Assume addressing and routing are correctly configured



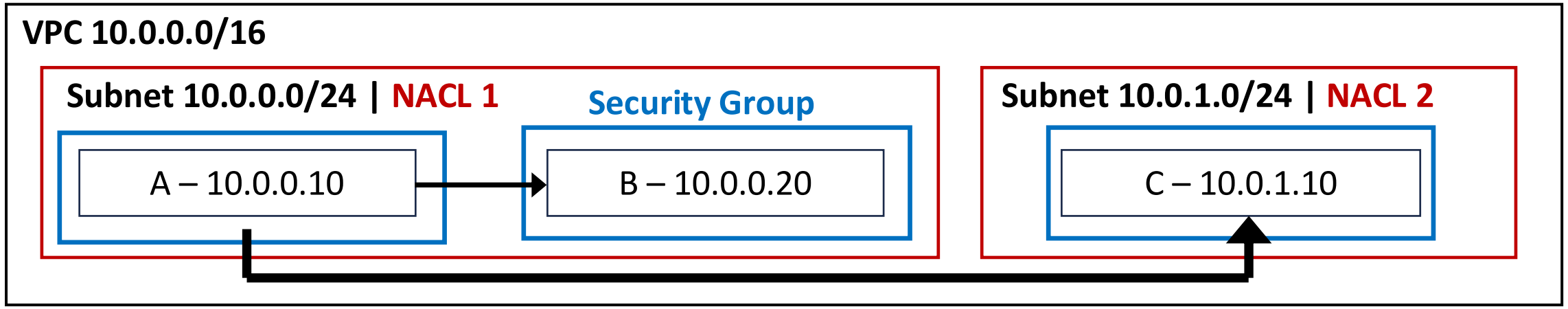

- Inbound SSH request: destination port 22
  - The inbound NACL rules must allow the request
  - The inbound SG rules must also allow the request
- Outbound SSH response: destination port 53124
  - The SG automatically allows the response based on connection state
  - The outbound NACL rules must independently allow the response

# Traffic Within and Across Subnets



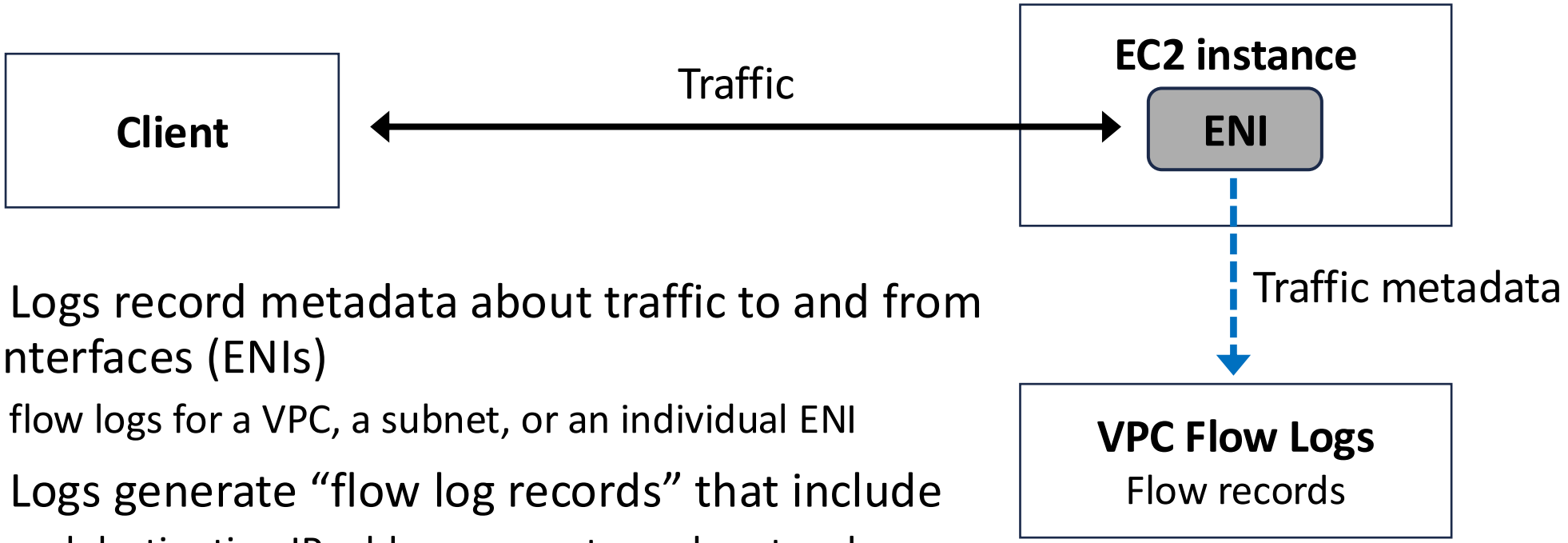

- The VPC's local route provides paths between its subnets
  - Creating separate subnets does not automatically block communication
- A → B: same subnet
  - A's outbound SG rules and B's inbound SG rules must allow the new connection
  - NACLs do not filter traffic that stays within the subnet

# Traffic Within and Across Subnets




- The VPC's local route provides paths between its subnets
  - Creating separate subnets does not automatically block communication
- A → B: same subnet
  - A's outbound SG rules and B's inbound SG rules must allow the new connection
  - NACLs do not filter traffic that stays within the subnet
- A → C: different subnets
  - A's outbound SG rules and C's inbound SG rules must allow the new connection
  - NACL 1's outbound rules and NACL 2's inbound rules must also allow it

# VPC Flow Logs

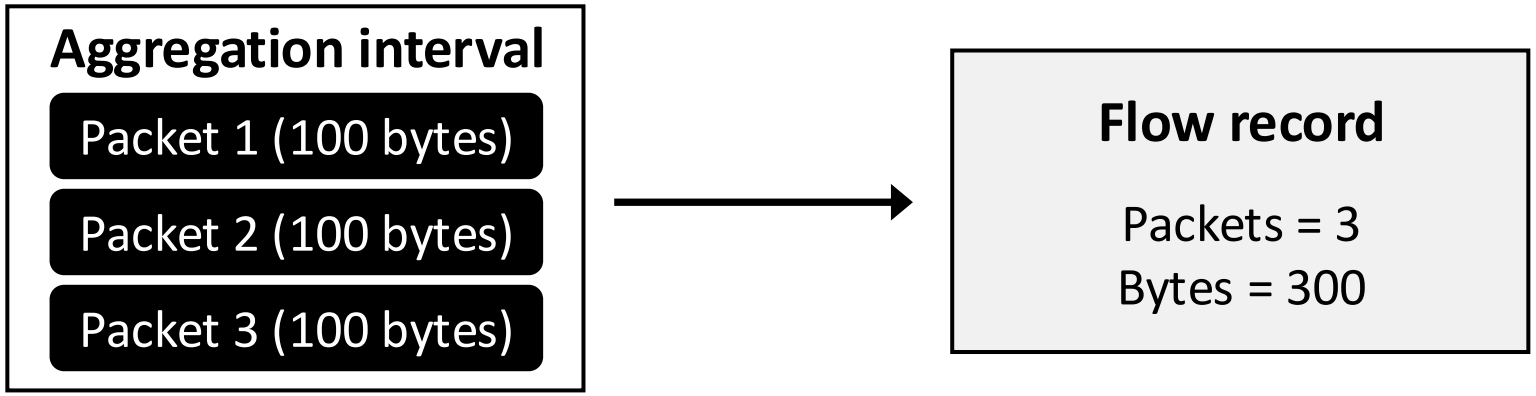



- VPC Flow Logs record metadata about traffic to and from network interfaces (ENIs)
  - Enable flow logs for a VPC, a subnet, or an individual ENI
- VPC Flow Logs generate “flow log records” that include
  - Source and destination IP addresses, ports, and protocol
  - Packet and byte counts, and traffic action (accept or reject)
- Flow Logs observe traffic without allowing or blocking it
  - Packet payloads are not recorded

# A Flow Record Covers an Interval

**Example: same flow at one ENI**

**TCP – 198.51.100.10:53124 → 10.0.0.10:22**




- A flow is identified by five fields (5-tuple):
  - Source IP, destination IP, source port, destination port, and protocol
- A flow record summarizes traffic from one flow at one ENI during an aggregation interval
  - Multiple packets can contribute to one record
- Records become available after aggregation, processing, and delivery
  - A one-minute aggregation interval does not guarantee delivery within one minute

# Reading a Flow Record

**Example flow record – Selected fields**

| Fields | Example values | Meaning |
|---|---|---|
| srcaddr → dstaddr | 198.51.100.10 → 10.0.0.10 | Source and destination IP addresses |
| srcport → dstport | 53124 → 22 | Source and destination ports |
| protocol | 6 | TCP |
| packets / bytes | 3 / 300 | 3 packets totaling 300 bytes |
| action | ACCEPT | Traffic was permitted |
| log-status | OK | Logging was operating normally |

- Read the addresses, ports, and protocol to identify the traffic
  - This example shows TCP traffic toward port 22 on 10.0.0.10
- Traffic acceptance and logging status describe different things
  - ACCEPT describes the traffic; OK describes the logging process

# Limits of VPC Flow Logs

- ACCEPT does not prove application success
  - SSH traffic may be accepted even when authentication fails
- REJECT does not identify the specific SG or NACL rule responsible
  - Review the relevant security group and network ACL configurations to investigate the cause
- No matching records does not prove that no traffic occurred
  - Check the logging scope, search time range, and possible delivery delays
  - Some types of traffic are not captured by VPC Flow Logs

# Summary

- VPCs and subnets
  - organize the network, while route tables determine paths
- Security groups
  - provide stateful, allow-only filtering at ENIs
- NACLs
  - provide stateless filtering using ordered allow/deny rules
- VPC Flow Logs
  - record traffic metadata for troubleshooting